

Section 05

Industrial Security (Bachelor)



Section 05 – Threat Landscape

Threat Landscape

Lecture Notes

Department of Computer Science

2026-05-18

Industrial Security (Bachelor)

Section 05

Industrial Security (Bachelor)



Section 05 – Threat Landscape

Threat Landscape
Lecture Notes
Department of Computer Science

- 1 Threat Actors and Frameworks
- 2 Case Studies
- 3 Cross-Cutting Risks

By the end of this section you will be able to

- Categorise threat actors targeting industrial environments.
- Map ICS attacks to the MITRE ATT&CK for ICS matrix.
- Analyse landmark incidents: Stuxnet, Ukraine, TRITON, Colonial.
- Identify supply-chain and insider risk vectors.

└ Learning Objectives

1

Threat Actors and Frameworks

- Nation-state APTs – Sandworm, Volt Typhoon, Lazarus
- Cybercrime / Ransomware – LockBit, BlackCat, Conti
- Hacktivists – CyberAv3ngers, GhostSec
- Insiders – disgruntled employees, contractors
- Opportunists – script kiddies, Shodan hunters
- Competitors – industrial espionage

2026-05-18

Industrial Security (Bachelor)
└ Threat Actors and Frameworks
└ Threat Actor Categories

Walk the ladder top-down and tie each tier to one named campaign the students will recognise later in the deck. For nation-state, pick Sandworm vs. Volt Typhoon as the contrast pair: Sandworm *breaks* things (Ukraine, NotPetya), Volt Typhoon *waits*. For ransomware, Colonial / DarkSide is the canonical OT-adjacent case. Hacktivists like CyberAv3ngers prove that low-skill actors with default credentials still take real water plants down. Stress that the categories are not exclusive — a single incident often involves a state actor renting a criminal botnet or hiring out wiper development. Insiders remain the highest-trust, lowest-noise threat: Maroochy Shire is the example we return to in the cross-cutting section.

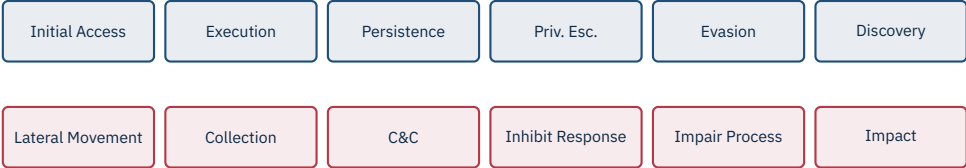
Threat Actor Categories

Nation-state APTs – Sandworm, Volt Typhoon, Lazarus
Cybercrime / Ransomware – LockBit, BlackCat, Conti
Hacktivists – CyberAv3ngers, GhostSec
Insiders – disgruntled employees, contractors
Opportunists – script kiddies, Shodan hunters
Competitors – industrial espionage

2026-05-18

Industrial Security (Bachelor)
Threat Actors and Frameworks

MITRE ATT&CK for ICS Tactics



Why this matters

ATT&CK for ICS gives a shared vocabulary for techniques, detections, and incident discussion across teams and vendors.

Read the matrix left-to-right as an attacker’s life cycle: get in, run code, stick, escalate, hide, look around, then move into the OT-specific bottom row — Lateral Movement through ICS networks, Collection of process data, C&C, then the three columns that distinguish ICS from enterprise ATT&CK: *Inhibit Response Function*, *Impair Process Control*, and *Impact*. Those last three are where safety and process engineering meet adversary tradecraft, and they are what the case studies later in this deck will keep landing in. Mention that ATT&CK for ICS started life as a 2020 spin-off from enterprise ATT&CK based on a 2018 Dragos technique catalogue. Tell the TA to push students to map each incident we cover onto two or three concrete techniques rather than just naming the tactic — e.g. Stuxnet’s HMI replay is T0856 “Spoof Reporting Message”, not just “Evasion”. Encourage referencing the live matrix on attack.mitre.org/matrices/ics/ during exercises.

2

Case Studies

- **Target:** Fuel Enrichment Plant, Natanz (Iran).
- **Victim hardware:** IR-1 gas centrifuge cascades, driven by Siemens S7-315 / S7-417 PLCs and Vacon / Fararo Paya VFDs.
- **Strategic goal:** delay Iranian uranium enrichment without overt military action.
- **Effect (2009–2010):** an estimated ~1 000 of ~8 700 IR-1s decommissioned at Natanz; enrichment throughput visibly stalled.
- **Attribution (widely reported):** joint US/Israel programme “Olympic Games”.

Cyber-physical weapon

Code that produces a *physical* effect (mass, energy, motion) by acting on a control system – distinct from data theft or denial of service.

Source: D. Albright, P. Brannan, C. Walrond, *Did Stuxnet Take Out 1,000 Centrifuges at Natanz?*, ISIS, 22 Dec 2010 | R. Langner, *To Kill a Centrifuge*, 2013.

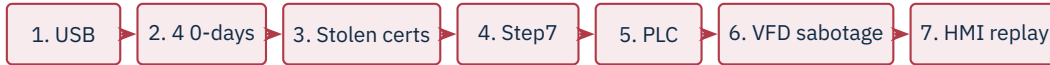
Stuxnet (2010) – Target and Objective

Frame this slide as the “why” before the “how”. The strategic problem in 2007–2010 was that the diplomatic track on Iran’s nuclear programme had stalled and an Israeli air-strike on Natanz was on the table. Stuxnet was the alternative. Make sure students grasp that the target was not Iran in general, not Natanz in general, but specifically the IR-1 cascade configuration — the malware fingerprinted the exact number of centrifuges per cascade (164) before firing. The IR-1 itself is a 1970s Pakistani design (P-1), already at the edge of its mechanical envelope, which is what made small over-speed and under-speed excursions catastrophic. The ISIS estimate of ~1 000 decommissioned IR-1s is the most defensible number we have; avoid quoting higher figures that circulated in the press. Save “Olympic Games” attribution for the next slide if a student asks early.

- **Target:** Fuel Enrichment Plant, Natanz (Iran).
- **Victim hardware:** IR-1 gas centrifuge cascades, driven by Siemens S7-315 / S7-417 PLCs and Vacon / Fararo Paya VFDs.
- **Strategic goal:** delay Iranian uranium enrichment without overt military action.
- **Effect (2009–2010):** an estimated ~1 000 of ~8 700 IR-1s decommissioned at Natanz; enrichment throughput visibly stalled.
- **Attribution (widely reported):** joint US/Israel programme “Olympic Games”.

Cyber-physical weapon
Code that produces a *physical* effect (mass, energy, motion) by acting on a control system – distinct from data theft or denial of service.

Source: D. Albright, P. Brannan, C. Walrond, *Did Stuxnet Take Out 1,000 Centrifuges at Natanz?*, ISIS, 22 Dec 2010 | R. Langner, *To Kill a Centrifuge*, 2013.



- **4 Windows zero-days** (LNK CVE-2010-2568, print-spooler, two privilege escalations) – unprecedented for a single payload.
- **Stolen code-signing certificates** from Realtek and JMicron used to sign kernel drivers.
- **USB-borne propagation**, then lateral movement on engineering LANs; final stage hooks the Siemens Step7 / WinCC DLLs to inject custom ladder logic.
- **Sabotage logic:** drove Fararo Paya / Vacon VFDs outside spec – alternating ~1 410 Hz and ~2 Hz bursts (normal: ~807–1 210 Hz), stressing rotors over weeks.
- **HMI deception:** 21 seconds of *recorded normal* sensor data played back during attacks – operators saw a healthy plant.

Source: N. Falliere, L. Murchu, E. Chien, *W32.Stuxnet Dossier v1.4*, Symantec, Feb 2011 | R. Langner, *To Kill a Centrifuge*, The Langner Group, Nov 2013.



Stress the operational genius of the recorded-replay trick: it is a worm that knew when to lie. Operators at Natanz reported nothing unusual for months while the centrifuges were dying. The 21-second replay window is documented in the Symantec dossier and is the detail that converted Stuxnet from “a worm” into “a weapon.” Walk them through why the four zero-days mattered together — LNK got you onto the engineering station, the spooler bug let you spread, the two priv-esc bugs got you SYSTEM. Pre-empt the romantic narrative: this was not a clever hacker, this was a multi-year, multi-agency programme with the kind of intel a research team could not assemble alone. Note that the worm was discovered only because a buggy replication routine caused it to spread far beyond Natanz; VirusBlokAda in Belarus filed the first sample in June 2010 after Iranian customer machines kept bluescreening. Transition: “so what does it take to find something like this in your network?”

★ Key Takeaway: Why Stuxnet still matters

- **Air gap is not a control.** USB sticks, engineer laptops, and vendor service notebooks cross it routinely. Treat it as a hurdle, not a boundary.
- **Supply chain matters.** Stolen vendor certificates defeated driver-signing checks. Trust placed in suppliers is trust placed in their security.
- **PLCs run unverified code.** S7 PLCs accepted any signed Step7 download; no firmware-level integrity check on logic blocks. Most PLCs still do.
- **The HMI is not ground truth.** A compromised controller can fake telemetry. Independent measurement (process tags, safety I/O, physical inspection) matters.

Source: R. Langner, *To Kill a Centrifuge*, 2013 | K. Zetter, *Countdown to Zero Day*, Crown, 2014.

★ Key Takeaway: Why Stuxnet still matters

- **Air gap is not a control.** USB sticks, engineer laptops, and vendor service notebooks cross it routinely. Treat it as a hurdle, not a boundary.
- **Supply chain matters.** Stolen vendor certificates defeated driver-signing checks. Trust placed in suppliers is trust placed in their security.
- **PLCs run unverified code.** S7 PLCs accepted any signed Step7 download; no firmware-level integrity check on logic blocks. Most PLCs still do.
- **The HMI is not ground truth.** A compromised controller can fake telemetry. Independent measurement (process tags, safety I/O, physical inspection) matters.

Source: R. Langner, *To Kill a Centrifuge*, 2013 | K. Zetter, *Countdown to Zero Day*, Crown, 2014.

Use this slide to push back on three comforting myths students walk in with. Myth one — “we are air-gapped, so this cannot happen”. Reply: every PLC programmer plugs a laptop into the engineering port; every vendor service tech brings a USB stick; the gap is permeable by design. Myth two — “signed code is safe code”. Reply: Stuxnet’s drivers were signed by Realtek and JMicron, both real Taiwanese vendors whose certificates were stolen, and Windows happily loaded them. Myth three — “the HMI shows what is happening”. Reply: the HMI shows what the PLC says is happening, and the PLC was lying. Land the closing point about firmware integrity: most S7-300/400 deployments today still cannot tell you whether the running OB1 is the OB1 engineering committed. Zetter’s *Countdown to Zero Day* is the most accessible long-form source if a student wants more.

- **When:** 23 December 2015, ~15:35 local time.
- **Who hit:** three regional distribution companies (oblenergos) – Prykarpattiaoblenergo, Chernivtsioblenergo, Kyivoblenergo.
- **Impact:** ~225 000 customers lost power; outages 1–6 hours; restoration required *manual* switching at substations because remote control was destroyed.
- **Aftermath:** weeks of degraded SCADA – operators ran the grid by phone and clipboard.

First confirmed cyber-induced power outage

Ukraine 2015 demonstrated that a remote actor could move from corporate IT to the SCADA HMI of a distribution operator and switch the lights off – in production, against three utilities, in coordinated fashion.

Source: R. M. Lee, M. J. Assante, T. Conway, *Analysis of the Cyber Attack on the Ukrainian Power Grid*, SANS/E-ISAC, 18 Mar 2016.

Ukraine 2015 – BlackEnergy and the First Blackout

Ground the story in the date: this is the first winter after Russia's annexation of Crimea and the start of the Donbas war, so the geopolitical frame is hot and the targeting is not random. Three utilities, hit within roughly half an hour of each other, is the part to emphasise — this was a coordinated operation, not a smash-and-grab. The restoration detail is the lesson worth lingering on: Ukrainian engineers drove to substations and threw switches by hand, which is only possible because Ukrainian distribution still kept manual fall-back. Ask the room: could your local DSO run for a week without SCADA? The SANS/E-ISAC report by Lee, Assante and Conway is the canonical source; the US ICS-CERT alert IR-ALERT-H-16-056-01 is the official confirmation. Mention that BlackEnergy is the same toolkit family Sandworm had been refining since 2007.

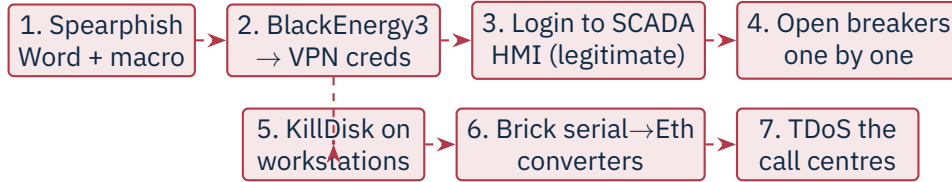
Ukraine 2015 – BlackEnergy and the First Blackout

- **When:** 23 December 2015, ~15:35 local time.
- **Who hit:** three regional distribution companies (oblenergos) – Prykarpattiaoblenergo, Chernivtsioblenergo, Kyivoblenergo.
- **Impact:** ~225 000 customers lost power; outages 1–6 hours; restoration required manual switching at substations because remote control was destroyed.
- **Aftermath:** weeks of degraded SCADA – operators ran the grid by phone and clipboard.

First confirmed cyber-induced power outage

Ukraine 2015 demonstrated that a remote actor could move from corporate IT to the SCADA HMI of a distribution operator and switch the lights off – in production, against three utilities, in coordinated fashion.

Source: R. M. Lee, M. J. Assante, T. Conway, *Analysis of the Cyber Attack on the Ukrainian Power Grid*, SANS/E-ISAC, 18 Mar 2016.



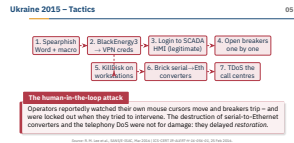
The human-in-the-loop attack

Operators reportedly watched their own mouse cursors move and breakers trip – and were locked out when they tried to intervene. The destruction of serial-to-Ethernet converters and the telephony DoS were not for damage: they delayed *restoration*.

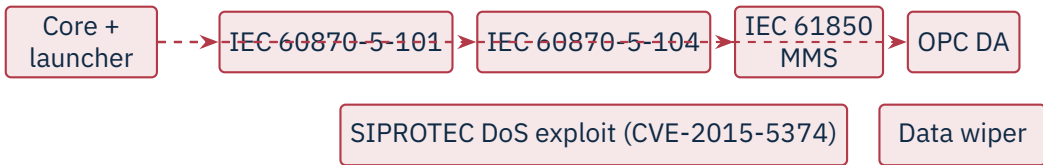
Source: R. M. Lee et al., SANS/E-ISAC, Mar 2016 | ICS-CERT IR-ALERT-H-16-056-01, 25 Feb 2016.

Ukraine 2015 – Tactics

This is the slide where students realise the attackers did not use exotic malware to open breakers – they used the operators’ own HMI clients, logged in with stolen VPN credentials, after six months of quiet reconnaissance. Walk left-to-right and stop on step three: this is hands-on-keyboard, human attackers driving SCADA software live. Then highlight the post-impact moves, because they are the genuinely novel part. Bricking the serial-to-Ethernet converters at the substations meant that even when IT was restored, operators could not remote-command the breakers – they had to physically travel. The telephony denial-of-service against the call centres meant customers could not report outages, slowing situational awareness. Together those are an attack on the *response* capability, which is exactly the ATT&CK for ICS “Inhibit Response Function” tactic. If asked about the phishing lure – it was a malicious Excel macro carried by a Word doc impersonating the Rada (parliament).



- **When:** 17 December 2016, just before midnight.
- **Where:** Pivnichna 330 kV transmission substation, north of Kyiv.
- **Impact:** ~200 MW dropped; ~1 hour outage in parts of Kyiv. Smaller than 2015 in scope – but qualitatively different.
- **Why it stands out:** the first known malware framework *purpose-built* to speak grid protocols, with swappable payload modules.



Source: A. Cherepanov, *Win32/Industroyer: A new threat for industrial control systems*, ESET, 12 Jun 2017 | Dragos, *CRASHOVERRIDE: Analysis of the Threat to Electric Grid Operations*, 2017.

2026-05-18

Ukraine 2016 – Industroyer / CrashOverride

Contrast immediately with 2015: a year later, the same actor came back, but this time the attack ran itself. No operator in the loop; the malware spoke IEC 60870-5-101 (serial), 101’s TCP cousin 104, IEC 61850 MMS, and OPC DA — the four protocols you need to operate a European or Ukrainian substation. Anatoly Cherepanov of ESET and Dragos’s Joe Slowik / Robert Lee published the parallel analyses in June 2017; ESET named it Industroyer, Dragos named it CRASHOVERRIDE, and the community now uses both. Use the diagram to make the framework point concrete: *core + launcher + protocol module* mirrors a Metasploit-style architecture. Mention that the SIPROTEC CVE-2015-5374 module crashed Siemens protection relays with a single malformed UDP packet — a deliberate attempt to take the safety layer down before tripping breakers, so reclosing would cause damage. The outage itself was modest in scope, but the message was strategic.

Ukraine 2016 – Industroyer / CrashOverride

- **When:** 17 December 2016, just before midnight.
- **Where:** Pivnichna 330 kV transmission substation, north of Kyiv.
- **Impact:** ~200 MW dropped; ~1 hour outage in parts of Kyiv. Smaller than 2015 in scope – but qualitatively different.
- **Why it stands out:** the first known malware framework purpose-built to speak grid protocols, with swappable payload modules.

Source: A. Cherepanov, *Win32/Industroyer: A new threat for industrial control systems*, ESET, 12 Jun 2017 | Dragos, *CRASHOVERRIDE: Analysis of the Threat to Electric Grid Operations*, 2017.

- Earlier ICS malware (Stuxnet, Havex) was *target-specific*. Industroyer is a *framework* – swap a payload, hit a different protocol.
- Built-in protocol handlers send legitimate-looking control commands; defenders see normal SCADA traffic.
- The SIPROTEC DoS module attempted to take protective relays *offline* ahead of the breaker operations – a deliberate attack on the safety layer.
- Attributed to **Sandworm** (Russian GRU Unit 74455).

Reusable grid weaponry

With Industroyer, ICS attack tooling crossed the line from bespoke ordinance to a *platform*. Subsequent variants (Industroyer2, 2022) reused the architecture against a Ukrainian substation – and were stopped before impact.

Source: A. Cherepanov, ESET, 2017 | Dragos, CRASHOVERRIDE, 2017 | ESET & CERT-UA, Industroyer2, 12 Apr 2022.

2026-05-18

Industrial Security (Bachelor)

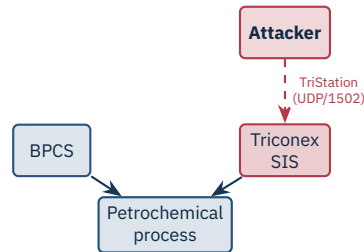
Case Studies

Industroyer – Significance and Attribution

Attribution to Sandworm / GRU Unit 74455 holds up because the same group's infrastructure, code overlaps, and operational tempo connect Industroyer to BlackEnergy, NotPetya, the 2018 Olympic Destroyer false-flag, and Industroyer2 in 2022. The 2020 US DoJ indictment of six GRU officers named the unit explicitly. The Industroyer2 episode is worth telling: in April 2022, six weeks into the full-scale invasion of Ukraine, ESET and CERT-UA caught a hard-coded Industroyer2 binary aimed at a Ukrainian high-voltage substation; CERT-UA, working with ESET and Microsoft, stopped it before execution. The lesson for students is that ICS attack tooling now has a development lineage – frameworks get versioned, modularised, and re-used. The takeaway box should land hard: defenders should expect future ICS malware to look more like Industroyer than like Stuxnet.

- Earlier ICS malware (Stuxnet, Havex) was *target-specific*. Industroyer is a *framework* – swap a payload, hit a different protocol.
- Built-in protocol handlers send legitimate-looking control commands; defenders see normal SCADA traffic.
- The SIPROTEC DoS module attempted to take protective relays offline ahead of the breaker operations – a deliberate attack on the safety layer.
- Attributed to **Sandworm** (Russian GRU Unit 74455).

Reusable grid weaponry
With Industroyer, ICS attack tooling crossed the line from bespoke ordinance to a platform. Subsequent variants (Industroyer2, 2022) reused the architecture against a Ukrainian substation – and were stopped before impact.



- **Where:** Saudi petrochemical plant (Tasnee/Sadara reported), Aug 2017.
- **Hit:** Schneider **Triconex** SIS – the last-resort trip-to-safe layer.
- **Goal:** disable SIS so a separate process attack could cause a release, fire, or explosion.
- **Outcome:** payload logic error caused SIS to fail-safe trip – shutting the plant down and exposing the operation.

Source: Dragos, *TRISIS Malware Analysis*, Dec 2017 | Mandiant/FireEye, *Attackers Deploy New ICS Attack Framework “TRITON”*, 14 Dec 2017.

2026-05-18

Industrial Security (Bachelor)
Case Studies

TRITON / TRISIS / HatMan (2017) – Target

Set the scene first: a petrochemical plant has at least two independent control layers, the BPCS (Basic Process Control System) that runs the process day-to-day and the SIS (Safety Instrumented System) that exists only to trip the plant to a safe state if the BPCS or the process itself fails. Schneider’s Triconex is a triple-redundant SIS used in tens of thousands of high-hazard facilities worldwide. The attacker did not want to break the SIS for its own sake — they wanted to *neutralise* it so a separate, future attack on the BPCS could push the process past a dangerous limit without any trip. That is the part that makes responders’ blood run cold. The operation was outed only because the payload contained a logic bug that caused two Triconex controllers to fail-safe and shut the plant in August 2017. Without that bug, we might not know about TRITON yet. Saudi attribution of the site (Tasnee or Petro Rabigh / Sadara) comes from reporting by Nicole Perlroth (NYT, 2018).

TRITON / TRISIS / HatMan (2017) – Target

- **Where:** Saudi petrochemical plant (Tasnee/Sadara reported), Aug 2017.
- **Hit:** Schneider **Triconex** SIS – the last-resort trip-to-safe layer.
- **Goal:** disable SIS so a separate process attack could cause a release, fire, or explosion.
- **Outcome:** payload logic error caused SIS to fail-safe trip – shutting the plant down and exposing the operation.

Source: Dragos, TRISIS Malware Analysis, Dec 2017 | Mandiant/FireEye, Attackers Deploy New ICS Attack Framework “TRITON”, 14 Dec 2017.

- Attackers reached an engineering workstation with TriStation software, then pivoted onto the SIS network.
- Payload (trilog.exe + library.zip) spoke the proprietary **TriStation** protocol; exploited a Triconex weakness (CVE-2018-7522) to inject malicious *ladder logic* into the safety controller's RAM.
- Once resident, the implant could rewrite SIS logic – including *neutralising* trip set-points – and restore the original on demand.
- Attribution: **TEMP.Veles** / Xenotime (FSU-linked); US Treasury sanctioned TsNIIKhM in 2020.

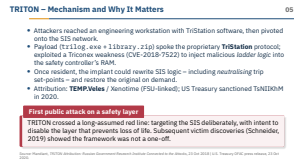
First public attack on a safety layer

TRITON crossed a long-assumed red line: targeting the SIS deliberately, with intent to disable the layer that prevents loss of life. Subsequent victim discoveries (Schneider, 2019) showed the framework was not a one-off.

Source: Mandiant, *TRITON Attribution: Russian Government Research Institute Connected to the Attacks*, 23 Oct 2018 | U.S. Treasury OFAC press release, 23 Oct 2020.

TRITON – Mechanism and Why It Matters

This is the most technically dense case study in the deck — slow down. The implant's value is that it can read, write, and *revert* safety logic on the Triconex MP3008 main processor, all over the proprietary TriStation UDP/1502 protocol that Schneider never published. Reverse-engineering that protocol is what made the Mandiant and Dragos analyses landmark publications. Attribution is unusually solid: Mandiant traced infrastructure and tooling back to TsNIIKhM, the Central Scientific Research Institute of Chemistry and Mechanics in Moscow, and the US Treasury sanctioned TsNIIKhM by name in October 2020 — one of the very few times a state research institute has been publicly named for an ICS attack. Mention the follow-on Schneider discovery in 2019 (a second victim, never named publicly) which proved TRITON was a programme, not a one-shot. Close by pointing forward to PIPEDREAM: same modular pattern, broader vendor coverage, caught even earlier.



- **Initial vector:** compromised update of **M.E.Doc**, a Ukrainian tax-accounting product used by virtually every company doing business in Ukraine.
- **Spread:** EternalBlue (MS17-010) + Mimikatz + WMI/PsExec – minutes to ravage a flat Windows domain.
- **Pseudo-ransomware:** encrypted the MFT, demanded \$300 BTC, but “decryption IDs” were random. Intent was destruction.
- **OT-adjacent impact (IT outage took OT down):**
 - **Maersk:** ~\$300 M; rebuilt 4 000 servers, 45 000 PCs in 10 days; container terminals halted.
 - **Merck:** ~\$870 M; vaccine production disrupted.
 - **Mondelēz, FedEx/TNT, Reckitt, Saint-Gobain:** hundreds of millions each.
- Total damage estimated at \$10 B+; attributed by US/UK/EU to **Sandworm** (GRU).

Source: A. Greenberg, *Sandworm*, Doubleday, 2019 | White House attribution statement, 15 Feb 2018 | CISA TA17-181A, 1 Jul 2017.

2026-05-18

Industrial Security (Bachelor) └ Case Studies

└ NotPetya (2017) – Supply-Chain Wiper

Open by killing the “ransomware” framing: the ransom note was theatre. The encryption was one-way; the “personal installation key” shown to victims was random bytes. NotPetya was a wiper dressed as ransomware to muddy attribution and discourage immediate state response. The supply-chain vector matters: M.E.Doc was the Ukrainian equivalent of TurboTax for businesses, so by trojanising one update server the GRU achieved near-total coverage of Ukrainian corporate IT. The collateral was the lesson: Maersk, Merck, FedEx/TNT, Mondelēz, Reckitt, Saint-Gobain were not the target, they were bystanders connected to Ukrainian subsidiaries. Andy Greenberg’s *Sandworm* has the Maersk recovery story in detail — the entire domain controller fleet was wiped, and a single surviving DC in Ghana (offline during the attack for an unrelated power outage) was the only seed left to rebuild from. Use this slide to introduce the section’s recurring theme: OT can be lost without OT being touched, if the IT it depends on is wiped.

NotPetya (2017) – Supply-Chain Wiper

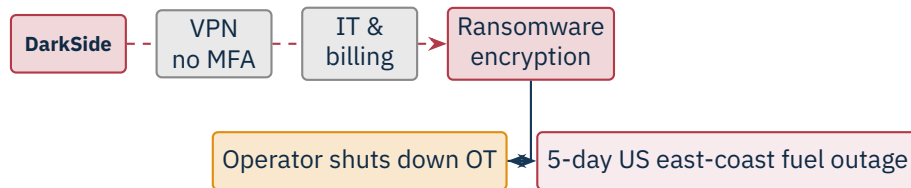
05

- **Initial vector:** compromised update of **M.E.Doc**, a Ukrainian tax-accounting product used by virtually every company doing business in Ukraine.
- **Spread:** EternalBlue (MS17-010) + Mimikatz + WMI/PsExec – minutes to ravage a flat Windows domain.
- **Pseudo-ransomware:** encrypted the MFT, demanded \$300 BTC, but “decryption IDs” were random. Intent was destruction.
- **OT-adjacent impact (IT outage took OT down):**
 - **Maersk:** ~\$300 M; rebuilt 4 000 servers, 45 000 PCs in 10 days; container terminals halted.
 - **Merck:** ~\$870 M; vaccine production disrupted.
 - **Mondelēz, FedEx/TNT, Reckitt, Saint-Gobain:** hundreds of millions each.
- Total damage estimated at \$10 B+; attributed by US/UK/EU to **Sandworm** (GRU).

Source: A. Greenberg, *Sandworm*, Doubleday, 2019 | White House attribution statement, 15 Feb 2018 | CISA TA17-181A, 1 Jul 2017.

Colonial Pipeline (2021) – IT/OT Coupling

05



- **7 May 2021:** DarkSide affiliate enters via a reused VPN password; no MFA.
- OT was *not* compromised. Colonial halted the 8 850 km pipeline because billing/dispatch IT was down.
- \$4.4 M ransom paid; ~half later recovered by the FBI; fuel shortages in 17 states.

★ Key Takeaway: IT/OT dependencies cut both ways

You can shut down OT without touching it – if the IT it depends on goes down.

Source: FBI, *Statement on Colonial Pipeline*, 10 May 2021 | GAO-22-104746, 2022.

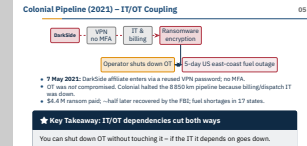
2026-05-18

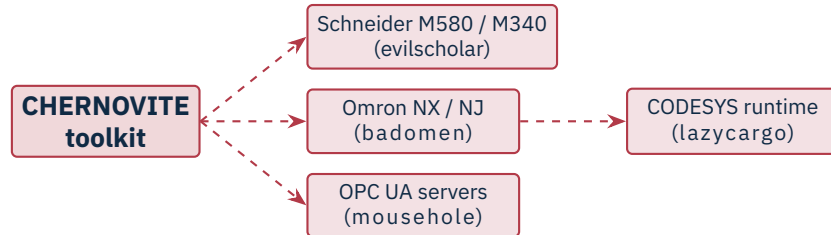
Industrial Security (Bachelor)

Case Studies

Colonial Pipeline (2021) – IT/OT Coupling

This is the case study to use when an executive asks “why do we care about OT security if the attack only hits IT?” The answer is in the takeaway box: Colonial chose to halt the pipeline. The decision was driven by their billing and dispatch systems being encrypted — they could move fuel but they could not invoice for it, and they could not be sure the OT network had not been touched, so they shut down. That is a perfectly rational business decision that produced a five-day fuel crisis on the US east coast and panic-buying as far inland as Tennessee. The initial-access detail is unglamorous and important: one legacy VPN account, no MFA, password found in a previously leaked credential dump. Mandiant did the IR. The FBI recovered roughly half of the \$4.4 M ransom (about 63.7 BTC) by tracing the DarkSide wallet — a rare positive note. The DHS/TSA response was the first binding cybersecurity directive on US pipeline operators (SD Pipeline-2021-01 and -02).





Caught before deployment

PIPEDREAM is the first modular ICS attack framework discovered *before any victim impact*. Pre-built modules for Schneider, Omron and OPC UA; capable of scanning, parameter changes, logic upload, and denial of control. Interdicted via early reporting by a partner.

Source: CISA AA22-103A, "APT Cyber Tools Targeting ICS/SCADA Devices", 13 Apr 2022 | Dragos, *PIPEDREAM/CHERNOVITE* report, Apr 2022 | Mandiant, *INCONTROLLER*, Apr 2022.

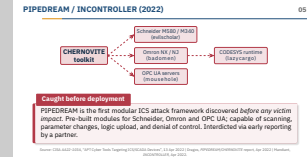
2026-05-18

Industrial Security (Bachelor)

Case Studies

PIPEDREAM / INCONTROLLER (2022)

The headline is in the importantbox: this is the first ICS-specific attack framework we found *before* it was used in anger. Dragos calls the toolkit PIPEDREAM and the actor CHERNOVITE; Mandiant uses INCONTROLLER; the joint CISA/DOE/NSA/FBI advisory AA22-103A is the official wrapper. The modules are vendor-specific: evilscholar targets Schneider M580/M340 Modicon controllers, badomen targets Omron NX/NJ (and can drop a custom agent on the controller), mousehole abuses OPC UA servers as an OT-to-OT pivot, and lazycargo drops a vulnerable signed driver to gain kernel access on the engineering workstation. Stress the OPC UA module — because OPC UA is the lingua franca of modern ICS data exchange, a framework that speaks it natively is vendor-agnostic by construction. Attribution is still public-officially undisclosed; Dragos's analysis leans Russia-state, which fits the February 2022 timing. Pivot into the next slide: low-skill actors do not need this kind of toolkit because default credentials still work.



The basics still get exploited

Default credentials (1111) and **direct Internet exposure** of PLCs are still common – and still get exploited by low-skill actors at scale.

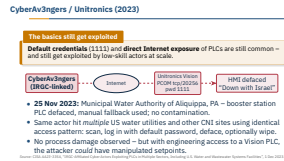


- **25 Nov 2023:** Municipal Water Authority of Aliquippa, PA – booster station PLC defaced, manual fallback used; no contamination.
- Same actor hit *multiple* US water utilities and other CNI sites using identical access pattern: scan, log in with default password, deface, optionally wipe.
- No process damage observed – but with engineering access to a Vision PLC, the attacker *could* have manipulated setpoints.

Source: CISA AA23-335A, “IRGC-Affiliated Cyber Actors Exploiting PLCs in Multiple Sectors, Including U.S. Water and Wastewater Systems Facilities”, 1 Dec 2023.

CyberAv3ngers / Unitronics (2023)

Use this as the deliberate anti-climax after PIPEDREAM. CyberAv3ngers — an IRGC-linked persona that emerged after 7 October 2023 — did not need zero-days or custom frameworks. They scanned the Internet for Unitronics Vision PLCs (an Israeli-made line), connected on TCP/20256 (PCOM), and tried the factory-default password 1111. That worked at the Aliquippa, PA water authority and at municipal and small industrial sites across at least half a dozen US states. The defacement was symbolic, but the underlying access let them push arbitrary ladder logic. Aliquippa fell back to manual operation within hours; no contamination occurred. The lesson for students is not glamorous but it is the most actionable in the entire deck: an Internet-exposed PLC with a default password is the most common ICS vulnerability in the world, and the cost to fix it is zero. CISA’s AA23-335A is the authoritative reference.



- Suspected PRC-linked APT, active since at least 2021.
- Targets: US critical infrastructure – communications, energy, water, transportation – with emphasis on assets serving **Guam** and the US west coast.
- Apparent objective: *pre-position* for disruptive or destructive action against OT during a future geopolitical crisis (e.g. Taiwan contingency).
- Dwell time before discovery in several victims: **five years or more**.

Caution

From espionage to pre-positioning Volt Typhoon’s target list (water, power, ports) and its persistence in OT-adjacent environments are consistent with preparation to *disrupt*, not to spy – a notable shift in intent.

Source: CISA AA24-038A, 7 Feb 2024 | Microsoft Threat Intelligence, *Volt Typhoon targets US critical infrastructure with living-off-the-land techniques*, 24 May 2023.

2026-05-18

Industrial Security (Bachelor)

Case Studies

Volt Typhoon (2023–2024) – Pre-positioning

Frame Volt Typhoon as a strategic shift, not just another APT. Microsoft Threat Intelligence published the first public profile on 24 May 2023; the joint CISA/NSA/FBI advisory AA24-038A in February 2024 added the multi-victim picture and the five-year dwell-time figure — read that one slowly to the room. The target set is the giveaway: water, electricity, ports, and communications, with a striking overconcentration on Guam, which would be a logistics hub in any Pacific contingency. That mix is not consistent with espionage, which would prioritise R&D or political targets, and it is consistent with preparing the battlefield. FBI Director Wray testified to Congress in early 2024 calling this exactly that — pre-positioning for disruptive effects against US CNI in a crisis. Mention that “Volt Typhoon” is Microsoft’s naming; Mandiant tracks much of the same activity as “VOLTzite”, Dragos as “VOLTzite” as well. Pivot into the next slide on *how* they stay hidden.

Volt Typhoon (2023–2024) – Pre-positioning

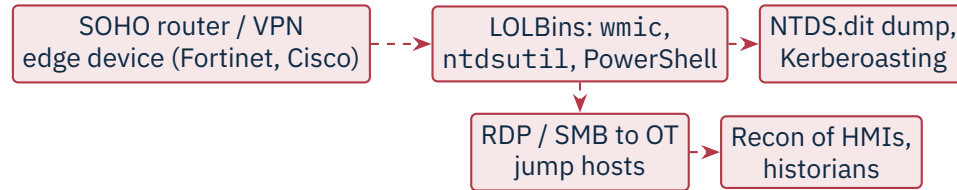
05

- Suspected PRC-linked APT, active since at least 2021.
- Targets: US critical infrastructure – communications, energy, water, transportation – with emphasis on assets serving **Guam** and the US west coast.
- Apparent objective: *pre-position* for disruptive or destructive action against OT during a future geopolitical crisis (e.g. Taiwan contingency).
- Dwell time before discovery in several victims: **five years or more**.

Caution

From espionage to pre-positioning Volt Typhoon’s target list (water, power, ports) and its persistence in OT-adjacent environments are consistent with preparation to *disrupt*, not to spy – a notable shift in intent.

Source: CISA AA24-038A, 7 Feb 2024 | Microsoft Threat Intelligence, Volt Typhoon targets US critical infrastructure with living-off-the-land techniques, 24 May 2023.



- **Initial access:** CVEs in Internet-facing Fortinet, Ivanti, Cisco appliances; or stolen creds.
- **Living off the land:** almost no custom malware – built-in Windows tools, signed binaries, multi-hop proxying through compromised SOHO routers (the “KV-botnet”).
- **Behaviour, not signatures:** the hardest threat to detect is the one that looks like a normal admin task.

Source: CISA AA24-038A, 7 Feb 2024 | Lumen Black Lotus Labs, KV-botnet, Dec 2023 | Microsoft, May 2023.

2026-05-18

Industrial Security (Bachelor)

Case Studies

Volt Typhoon – Living off the Land

“Living off the land” means the operator carries no malware; they use what is already on the box. That is wmic for remote execution, ntdsutil to dump the domain database, netsh for port-forwarding, PowerShell for everything else — all signed Microsoft binaries that no anti-virus will block. Detection has to be *behavioural*: who normally runs ntdsutil ifm create full at 3am? The KV-botnet detail is worth telling: Lumen Black Lotus Labs in December 2023 documented hundreds of compromised Cisco RV-series and Netgear ProSAFE SOHO routers in the US that were being used as proxy hops to obscure the actor’s true origin. The FBI took the botnet down by court order in late January 2024 — one of the few overt counter-strikes against this actor. Close the slide with the doctrinal point: anti-malware does not detect Volt Typhoon. Identity monitoring, EDR behavioural rules, and aggressive credential hygiene do. This is also why the OT/IT boundary matters — once they have domain admin, an OT jump host with cached IT credentials is the doorway.

Volt Typhoon – Living off the Land

- **Initial access:** CVEs in Internet-facing Fortinet, Ivanti, Cisco appliances; or stolen creds.
- **Living off the land:** almost no custom malware – built-in Windows tools, signed binaries, multi-hop proxying through compromised SOHO routers (the “KV-botnet”).
- **Behaviour, not signatures:** the hardest threat to detect is the one that looks like a normal admin task.

Source: CISA AA24-038A, 7 Feb 2024 | Lumen Black Lotus Labs, KV-botnet, Dec 2023 | Microsoft, May 2023

3

Cross-Cutting Risks



SolarWinds, 3CX, MOVEit – and OT-relevant cases such as Codesys runtime CVEs (*CoDe16*).

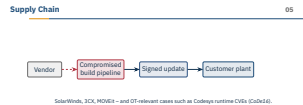
2026-05-18

Industrial Security (Bachelor)

└ Cross-Cutting Risks

└ Supply Chain

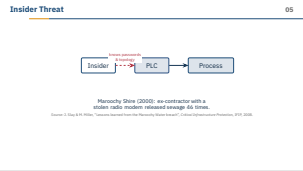
Use this as the bridge from named incidents to systemic risk. Three IT-world supply-chain cases are useful anchors — SolarWinds Orion (2020, trojanised build pipeline pushed signed updates to 18 000 organisations), 3CX (2023, a double supply-chain compromise where a trojanised X_{TRADER} app from Trading Technologies infected a 3CX developer who in turn shipped a backdoored softphone), and MOVEit (2023, Clop’s mass-exploitation of a managed-file-transfer SQL-injection bug). The OT-relevant case is *CoDe16* (Microsoft / Team82 Claroty, 2022): sixteen CVEs in the CODESYS V3 runtime, which is OEM’d into PLCs from dozens of vendors — one bug, hundreds of product lines affected. The point for the room: in OT you do not just trust your vendor, you trust the dozen upstream component vendors they trust. SBOM is not a checkbox here, it is the only way to answer “am I affected” inside a normal change window.



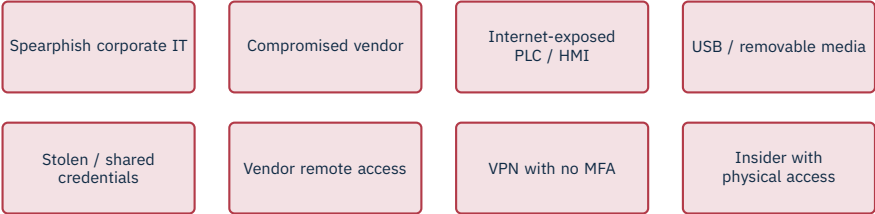


Maroochy Shire (2000): ex-contractor with a stolen radio modem released sewage 46 times.

Source: J. Slay & M. Miller, “Lessons learned from the Maroochy Water breach”, *Critical Infrastructure Protection*, IFIP, 2008.



Maroochy Shire (Queensland, Australia, 2000) is the canonical ICS insider case and the easiest one to remember. Vitek Boden had worked for the contractor that installed the Hunter Watertech radio-controlled SCADA at 142 pumping stations; after being refused a council job he kept the company laptop and a stolen radio modem, drove around the shire, and impersonated pumping station 4. Over two months, between January and April 2000, he triggered 46 separate sewage releases into parks, waterways and a Hyatt Regency hotel grounds before being caught with the gear in his car. He was sentenced to two years. Use this to make three points: insiders bring *authentic* credentials, they know the topology, and they know what is monitored. Standard perimeter controls do nothing against them. Slay & Miller’s IFIP paper is the academic write-up; the original prosecution narrative is in *R v Boden* (2002) QCA 164 if a student wants the legal record.



Source: Dragos Year in Review 2024 – initial access vectors observed across 23 OT-targeting groups.

2026-05-18

Industrial Security (Bachelor)
└ Cross-Cutting Risks

└ Common Initial Access Vectors in ICS

This is the slide to tie the case studies back into a defender’s prioritisation list. Map each tile to a case the students have just seen: spearphish-corporate-IT → Ukraine 2015; compromised-vendor → NotPetya via M.E.Doc; Internet-exposed PLC → CyberAv3ngers; USB → Stuxnet; stolen/shared credentials → Colonial; vendor remote access → Volt Typhoon’s edge appliances; VPN without MFA → Colonial again; insider with physical access → Maroochy. The Dragos *Year in Review* is the best public data set for relative frequency — in their 2024 numbers, exploitation of Internet-facing services and abuse of valid accounts dominate. Ask the room which of these their own organisation would catch in detection, which in prevention, and which in response. Then close: the rest of the course is the toolkit for answering that question.



★ Key Takeaway: What to remember from this section

- Threat actors range from script kiddies to nation-state APTs, each with different capabilities and intent.
- MITRE ATT&CK for ICS provides a shared vocabulary for techniques and detections.
- Stuxnet → Ukraine 2015 → Industroyer → TRITON → PIPEDREAM shows escalating capability and willingness to harm.
- NotPetya and Colonial Pipeline show that IT/OT coupling can take OT down without any OT compromise.
- Volt Typhoon shows that pre-positioning inside CNI – not espionage – is now an explicit objective.
- Supply chain and insider risk demand controls beyond the network perimeter.

Recap by tracing the capability curve in one breath: Stuxnet (2010) was a bespoke cyber-physical weapon requiring nation-state resources; Ukraine 2015 was hands-on-keyboard SCADA operation; Industroyer (2016) was the first reusable grid framework; TRITON (2017) crossed the SIS red line; PIPEDREAM (2022) is a vendor-agnostic toolkit caught pre-deployment; CyberAv3ngers (2023) proves low-skill actors still succeed with defaults; Volt Typhoon (2023–24) shifts the goal from spying to pre-positioning. The NotPetya / Colonial pair is the orthogonal lesson: OT can be lost without being touched. End with the question this section sets up for the rest of the course: *given this threat landscape, what controls actually move the needle?* That is the bridge into Sections 6 onward.

Summary – Section 05

05

★ Key Takeaway: What to remember from this section

- Threat actors range from script kiddies to nation-state APTs, each with different capabilities and intent.
- MITRE ATT&CK for ICS provides a shared vocabulary for techniques and detections.
- Stuxnet → Ukraine 2015 → Industroyer → TRITON → PIPEDREAM shows escalating capability and willingness to harm.
- NotPetya and Colonial Pipeline show that IT/OT coupling can take OT down without any OT compromise.
- Volt Typhoon shows that pre-positioning inside CNI – not espionage – is now an explicit objective.
- Supply chain and insider risk demand controls beyond the network perimeter.

- Falliere, N., Murchu, L., Chien, E. *W32.Stuxnet Dossier*, v1.4. Symantec, Feb 2011.
- Langner, R. *To Kill a Centrifuge*, The Langner Group, Nov 2013.
- Albright, D., Brannan, P., Walrond, C. *Did Stuxnet take out 1,000 centrifuges at Natanz?* ISIS, 22 Dec 2010.
- Zetter, K. *Countdown to Zero Day: Stuxnet and the Launch of the World’s First Digital Weapon*. Crown, 2014.
- Lee, R.M., Assante, M.J., Conway, T. *Analysis of the Cyber Attack on the Ukrainian Power Grid*, SANS/E-ISAC, 18 Mar 2016.
- ICS-CERT. *IR-ALERT-H-16-056-01: Cyber-Attack Against Ukrainian Critical Infrastructure*, 25 Feb 2016.
- Cherepanov, A. *Win32/Industroyer: A new threat for industrial control systems*, ESET, 12 Jun 2017.
- Dragos. *CRASHOVERRIDE: Analysis of the Threat to Electric Grid Operations*, 2017.
- ESET and CERT-UA. *Industroyer2: Industroyer reloaded*, 12 Apr 2022.
- Dragos. *TRISIS Malware Analysis of Safety System Targeted Malware*, Dec 2017.
- Mandiant/FireEye. *Attackers Deploy New ICS Attack Framework “TRITON”*, 14 Dec 2017.
- Mandiant. *TRITON Attribution: Russian Government Research Institute Connected to the Attacks*, 23 Oct 2018.
- U.S. Treasury OFAC. Press release on TsNIIKhM sanctions (TRITON), 23 Oct 2020.
- CISA *TA17-181A*. “Petya Ransomware”, 1 Jul 2017.
- White House. Statement attributing NotPetya to the Russian Government, 15 Feb 2018.

References – Section 05	05
• Falliere, N., Murchu, L., Chien, E. <i>W32.Stuxnet Dossier</i>, v1.4. Symantec, Feb 2011. • Langner, R. <i>To Kill a Centrifuge</i>, The Langner Group, Nov 2013. • Albright, D., Brannan, P., Walrond, C. <i>Did Stuxnet take out 1,000 centrifuges at Natanz?</i> ISIS, 22 Dec 2010. • Zetter, K. <i>Countdown to Zero Day: Stuxnet and the Launch of the World’s First Digital Weapon</i>. Crown, 2014. • Lee, R.M., Assante, M.J., Conway, T. <i>Analysis of the Cyber Attack on the Ukrainian Power Grid</i>, SANS/E-ISAC, 18 Mar 2016. • ICS-CERT. <i>IR-ALERT-H-16-056-01: Cyber-Attack Against Ukrainian Critical Infrastructure</i>, 25 Feb 2016. • Cherepanov, A. <i>Win32/Industroyer: A new threat for industrial control systems</i>, ESET, 12 Jun 2017. • Dragos. <i>CRASHOVERRIDE: Analysis of the Threat to Electric Grid Operations</i>, 2017. • ESET and CERT-UA. <i>Industroyer2: Industroyer reloaded</i>, 12 Apr 2022. • Dragos. <i>TRISIS Malware Analysis of Safety System Targeted Malware</i>, Dec 2017. • Mandiant/FireEye. <i>Attackers Deploy New ICS Attack Framework “TRITON”</i>, 14 Dec 2017. • Mandiant. <i>TRITON Attribution: Russian Government Research Institute Connected to the Attacks</i>, 23 Oct 2018. • U.S. Treasury OFAC. Press release on TsNIIKhM sanctions (TRITON), 23 Oct 2020. • CISA <i>TA17-181A</i>. “Petya Ransomware”, 1 Jul 2017. • White House. Statement attributing NotPetya to the Russian Government, 15 Feb 2018.	

- Greenberg, A. *Sandworm: A New Era of Cyberwar and the Hunt for the Kremlin’s Most Dangerous Hackers*. Doubleday, 2019.
- FBI. *Statement on the Colonial Pipeline attack*, 10 May 2021.
- GAO-22-104746. *Critical Infrastructure Protection: Federal Authorities – Colonial Pipeline Response*, 2022.
- TSA. *Security Directive Pipeline-2021-01*, May 2021.
- CISA AA22-103A. “APT Cyber Tools Targeting ICS/SCADA Devices” (PIPEDREAM/INCONTROLLER), 13 Apr 2022.
- Mandiant. *INCONTROLLER: New State-Sponsored Cyber Attack Tools*, Apr 2022.
- Dragos. *PIPEDREAM/CHERNOVITE*, Apr 2022.
- CISA AA23-335A. “IRGC-Affiliated Cyber Actors Exploiting PLCs in Multiple Sectors”, 1 Dec 2023.
- CISA AA24-038A. “PRC State-Sponsored Actors Compromise and Maintain Persistent Access to U.S. Critical Infrastructure” (Volt Typhoon), 7 Feb 2024.
- Microsoft Threat Intelligence. *Volt Typhoon targets US critical infrastructure with living-off-the-land techniques*, 24 May 2023.
- Lumen Black Lotus Labs. *KV-botnet: Don’t call it a comeback*, Dec 2023.
- Slay, J., Miller, M. “Lessons learned from the Maroochy Water breach.” In *Critical Infrastructure Protection*, IFIP, 2008.
- MITRE. *ATT&CK for ICS*, knowledge base, <https://attack.mitre.org/matrices/ics/>.
- Dragos. *Year in Review*, annual reports.

2026-05-18

Industrial Security (Bachelor)
└ Cross-Cutting Risks

└ References – Section 05

References – Section 05 (cont.)		05
2026-05-18	• Greenberg, A. <i>Sandworm: A New Era of Cyberwar and the Hunt for the Kremlin’s Most Dangerous Hackers</i> . Doubleday, 2019.	
	• FBI. <i>Statement on the Colonial Pipeline attack</i> , 10 May 2021.	
	• GAO-22-104746. <i>Critical Infrastructure Protection: Federal Authorities – Colonial Pipeline Response</i> , 2022.	
	• TSA. <i>Security Directive Pipeline-2021-01</i> , May 2021.	
	• CISA AA22-103A. “APT Cyber Tools Targeting ICS/SCADA Devices” (PIPEDREAM/INCONTROLLER), 13 Apr 2022.	
	• Mandiant. <i>INCONTROLLER: New State-Sponsored Cyber Attack Tools</i> , Apr 2022.	
	• Dragos. <i>PIPEDREAM/CHERNOVITE</i> , Apr 2022.	
	• CISA AA23-335A. “IRGC-Affiliated Cyber Actors Exploiting PLCs in Multiple Sectors”, 1 Dec 2023.	
	• CISA AA24-038A. “PRC State-Sponsored Actors Compromise and Maintain Persistent Access to U.S. Critical Infrastructure” (Volt Typhoon), 7 Feb 2024.	
	• Microsoft Threat Intelligence. <i>Volt Typhoon targets US critical infrastructure with living-off-the-land techniques</i> , 24 May 2023.	
	• Lumen Black Lotus Labs. <i>KV-botnet: Don’t call it a comeback</i> , Dec 2023.	
	• Slay, J., Miller, M. “Lessons learned from the Maroochy Water breach.” In <i>Critical Infrastructure Protection</i> , IFIP, 2008.	
	• MITRE. <i>ATT&CK for ICS</i> , knowledge base, https://attack.mitre.org/matrices/ics/ .	
	• Dragos. <i>Year in Review</i> , annual reports.	

End of Section 05

Threat Landscape

Questions and discussion

